CashPilot — Security Self-Assessment Report

FinTechathon 2026 International Track · Topic E: SME Finance Copilot
Assessment date: 2026-10-20 · **Code baseline:** submitted `main` branch · **Assessed by:** the CashPilot team (self-assessment)
Team: Sampad Chakma (@SamJU25) · Purno Dewan (@coderx86) · Binoy Kumar Chakma (@binoy-kumar-changmha) · Parban Chakma (@Parban1527)
Repository: https://github.com/SamJU25/F-SME-Finance-Copilot

This report covers (1) how the permission tiers are implemented and enforced, (2) the controls around them, (3) the evidence for each claim, and (4) the known-risk register. Each control is marked **Implemented**, **Partial** or **Planned**. Every Implemented claim points to the code that enforces it and to a test or log that shows it working.

---

1. Summary

Item	Result
Can the AI agent move money?	**No.** There is no execution route, no payment SDK, and no bank or lender credential anywhere in the system.
Permission tiers	3 tiers enforced server-side: Observe (autonomous) → Draft (signed tenant only) → Owner-sent (human only, never executed)
Security test suite	`tests/security/`: **54 passed, 1 skipped** (POSIX file-mode check, not applicable on Windows)
Full suite	**969 passed, 1 skipped**
Sandbox attack replay	**34/34** operations behaved as expected, including forged token, cross-tenant access, parameter smuggling, prompt injection with a valid token, and invoice double pledge
Dependency audit	Python (`pip-audit -r requirements.txt`): **no known vulnerabilities**. Frontend (`npm audit --omit=dev`): 13 advisories; the critical one is disabled at the config level, the rest are build-time tooling or low severity (R9)
Open risks	14 tracked (0 critical, 2 high, 7 medium, 5 low); see Section 5

---

2. Permission-Tier Implementation

2.1 Tier definitions

Tier	Scope	Actor	Money moved	State written
Tier 1 — Observe	Statement parsing, cash metrics, forecasts, underwriting, financing match, chat answers	Agent, autonomously, no login required	$0	Caller's own chat session only
Tier 2 — Draft	Proposals to draw a credit line, factor or pledge an invoice, or transfer funds	Agent or owner, with a **signed tenant token**	$0	One `STAGED_PENDING_HITL` record in that tenant's staging ledger
Tier 3 — Owner-sent	Anything that moves money or commits the business	**Owner only, outside the system**	$0 through CashPilot	Status change to `PREPARED` or `REJECTED`

2.2 How each tier is enforced

Tier 1 is read-only by construction. `POST /api/v1/analyze`, `/underwrite` and `/agent/chat` return calculations. All money uses `decimal.Decimal`, and the LLM narrates figures it is given; it does not compute them (`services/agent/prompts.py::numbers_are_grounded` rejects any reply quoting a figure absent from the engine output).

Tier 2 needs a verified identity and passes through a schema gate.

Control	Code	Evidence
Staging requires an HMAC-SHA256 signed tenant token (`Authorization: Bearer` or `X-Tenant-Token`)	`services/security/tenant_token.py`, `api/routes/actions.py`	Sandbox log #13 (anonymous → 401), #14 (forged → 401)
Tenant comes from the token, never from the request body or `X-Tenant-ID`	`require_tenant_identity`	`tests/security/test_action_gate_auth.py`
Token issuance needs an enrollment key bound to that tenant; comparison is constant-time (`hmac.compare_digest`); an unbound single key is fail-closed	`tenant_token.py` lines ~100–120	Sandbox log #9, #10 (no key / wrong tenant's key → 403)
Strict schemas: `extra="forbid"`, `amount_cents > 0` (integer cents)	`services/security/staging_ledger.py`, `three_tier_gate.py`	Sandbox log #29 (`execute_now` smuggled → 422), #30 (negative amount → 422)
Queue hygiene: pending proposals expire after 72 h; identical instruction inside 5 min returns the existing proposal	`staging_ledger.py` (`STAGED_INTENT_TTL_HOURS`, `STAGED_INTENT_DEDUPE_SECONDS`)	Sandbox log #16 (same intent id returned)
Anonymous chat cannot stage, even with staging parameters	`services/agent/supervisor.py`	Sandbox log #18
Prompt-injection and credential-paste checks run before intent routing and override staging parameters	`supervisor.py::detect_intent` → `SECURITY_GATE` decision domain	Sandbox log #19 (valid token + injection + `TRANSFER` params → blocked, nothing staged), #20

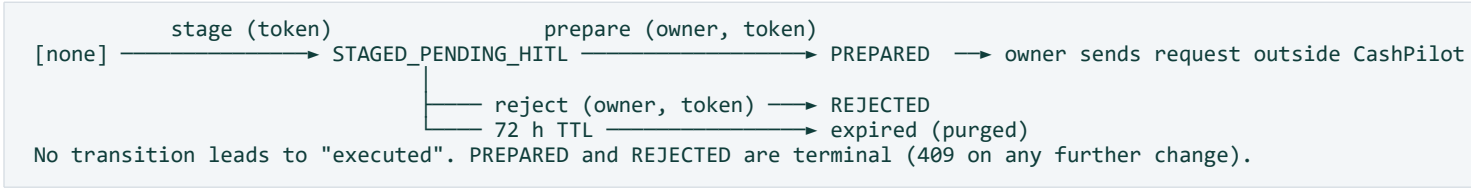
Tier 3 has no execution path.

Control	Code	Evidence
No `/execute` route exists; the only owner decisions are `prepare` and `reject`	`api/routes/actions.py`	Sandbox log #24 (`/execute` → 404); `tests/e2e/test_csv_upload_e2e.py`
`prepare` changes status only; the owner sends the pre-filled request from their own email or lender portal	`staging_ledger.py::prepare_intent`	Sandbox log #25
A decided proposal cannot be decided again	`staging_ledger.py::_decide`	Sandbox log #26 (second prepare → 409)
Which action types count as Tier 3 is a reviewed policy table, not scattered code	`contracts/decision_tables/security_gate_policy.json`, `three_tier_gate.py::requires_owner_action`	`tests/security/test_invariants.py`
No payment credentials: no bank API keys, card data or lender tokens are accepted, stored or configured	Whole codebase; `.env.example` has no such field	Code review; pasted API keys are flagged in chat (log #20)

2.3 Tenant isolation

Each staged intent is bound to the token's tenant. A lookup for another tenant's intent returns **404, not 403**, so intent IDs cannot be confirmed by probing (sandbox log #22 read, #23 prepare). Operator routes need `DECISION_ADMIN_KEY` and return 503 when it is unset (log #31).

2.4 Lifecycle



---

3. Supporting Controls

#	Control	Status	Where
C1	Per-IP token-bucket rate limit (default 60/min), honours `TRUSTED_PROXY_HOPS`	Implemented	`api/rate_limit.py`; `tests/security/test_rate_limit.py` (6 tests)
C2	Upload size limit (`MAX_ANALYSIS_UPLOAD_BYTES`, 10 MB) and PDF page/structure validation	Implemented	`services/ingestion/pdf_validator.py`
C3	Row-level rejection with reason codes; bad rows never change metrics silently	Implemented	`services/ingestion/csv_parser.py`; sandbox log #5
C4	PII masking before any cloud LLM call: account numbers, tax IDs, emails, phones, IBANs and API keys (regex), plus company and person names replaced with reversible `[PARTY_n]` placeholders that are restored in the reply	Implemented	`services/agent/llm_bridge.py::mask_p` `services/agent/name_masking.py`; `tests/security/test_invariants.py`, `tests/unit/test_name_masking.py` (6 tests, including the exact outgoing HTTP payload)
C5	SSRF guard on user-supplied LLM endpoints: blocks non-HTTP(S), embedded credentials, loopback, private ranges, link-local/metadata hosts; upstream error bodies not reflected	Implemented	`services/agent/url_guard.py`; `tests/security/test_url_guard.py` (12 tests)
C6	Local, air-gapped model option (MiniCPM5-2B); statement data never leaves the host in this mode	Implemented	`services/agent/local_transformers.py`
C7	Owner-only file permissions (`0700` dirs / `0600` files) and atomic writes for ledger, sessions, registry	Implemented	`services/security/file_utils.py`; `test_backend_hardening.py`
C8	Encryption at rest with Fernet when `COPILOT_DATA_KEY` is set (`enc:v1:` prefix); production/staging refuses to start without it	Implemented	`services/security/crypto.py`; `test_encryption_at_rest.py` (9 tests)
C9	Containers run as non-root users, `no-new-privileges`, `cap_drop`, health checks; `.data/` and `.sessions/` excluded from image build context	Implemented	`docker/Dockerfile.*`, `docker-compose.yml`
C10	Invoice double-pledge prevention via canonical SHA-256 hash, first pledge wins	Implemented (local simulation)	`services/blockchain/invoice_hasher.p` sandbox log #32–34
C11	Truth-in-Lending: true APR shown for every offer; > 36 % APR flagged predatory and excluded from defaults	Implemented	`services/calculations/bridge_plan.py` `services/matcher/liquidity_matcher.p`

#	Control	Status	Where
C12	Policy thresholds as versioned JSON decision tables; hot reload operator-only	Implemented	`contracts/decision_tables/`, `api/routes/decision.py`
C13	Grounding check: replies with figures not produced by the engine are discarded	Implemented	`services/agent/prompts.py` (`numbers_are_grounded`)
C14	CI runs tests and smoke-tests the container stack (token issuance, anonymous-staging refusal, sealed ledger)	Implemented	`.github/workflows/ci.yml`
C15	PostgreSQL with row-level security and append-only ledger tables	Planned	Design in `docs/architecture.md` §3.1
C16	Deployment of `InvoiceRegistry.sol` to a FISCO BCOS consortium chain	Planned	`contracts/InvoiceRegistry.sol` written, not deployed
C17	OIDC sign-in, per-user roles and token revocation	Planned	—

4. Threat Model

Threat	Attack	Primary defence	Residual risk
Agent misuse of funds	LLM or injected text tries to pay, draw or transfer	No execution route and no credentials (Tier 3 is owner-sent)	None through CashPilot; the owner can still be socially engineered outside it (R13)
Prompt injection	Instructions hidden in chat or in statement descriptions	Injection check before routing; LLM output limited to narration and Tier 2 drafts	Pattern-based detection can be evaded (R4); impact capped at a draft the owner must approve
Tenant hopping / IDOR	Change `tenant_id`, guess intent IDs	Tenant taken from signed token; 404 on mismatch	Low
Token forgery / theft	Craft or replay a bearer token	HMAC-SHA256 signature with expiry	Stolen tokens stay valid up to 30 days; no revocation (R2)
Parameter smuggling	Extra fields such as `execute_now`, negative amounts	`extra="forbid"`, positive-integer cents	Low
SSRF	Point the LLM base URL at internal or metadata hosts	URL guard	DNS rebinding between check and connect not fully covered (R8)
Data leakage to cloud LLM	Statement text sent to a third-party model	Identifier masking + reversible name masking; local-model option	One-word names and names built only from CashPilot's own vocabulary are not masked (R3)
Invoice double financing	Pledge one invoice to two lenders	Canonical hash registry, first pledge wins	Registry is local, so lenders outside this instance are not covered until on-chain deployment (R5)
Denial of service	Request floods, large uploads, proposal flooding	Rate limit, upload limits, TTL + dedupe, staging needs token	In-memory limiter per process (R7)
Stolen disk / backup	Copy `.data/` or `.sessions/`	Owner-only files; Fernet sealing with `COPILOT_DATA_KEY`	Encryption is opt-in for local development (R6)

5. Known-Risk Register

Severity uses likelihood × impact for a production deployment of the current build. Status: **Open** (accepted for the competition build, with a planned fix) or **Mitigated** (control in place, residual risk noted).

ID	Risk	Severity	Status	Current mitigation	Planned fix
R1	**Single-process JSON storage.** Ledger, sessions and registry use process-local locks; running several API workers could interleave writes.	High	Open	Single worker in Docker/compose; atomic file replace	PostgreSQL 16 with row locks and RLS (C15)
R2	**Bearer tokens last 30 days with no revocation list.** A leaked token allows staging and reading that tenant's proposals until expiry. It cannot move money.	High	Open	HMAC signature, expiry, tenant-scoped; Tier 3 never executes	Shorter TTL + refresh tokens, revocation list, OIDC (C17)
R3	**Name masking is heuristic.** Cloud-bound text has multi-word company and person names (Title Case or ALL CAPS, e.g. "Northwind Foods", "JOHN SMITH") replaced with `[PARTY_n]`, and the real names are restored in the reply. A one-word name ("Sarah") or a name made only of words CashPilot itself uses ("Capital Partners") is still sent as written.	Medium	Mitigated	`services/agent/name_masking.py` (stoplist harvested from CashPilot's own prompts, engines, policy tables and knowledge cards, so prompt headings stay readable); regex masking of identifiers; the default local model keeps all text on the host	Named-entity recognition model for single-word names
R4	**Prompt-injection detection uses patterns and a policy table**, so novel phrasing can evade it.	Medium	Mitigated	Even a missed injection can only produce a Tier 2 draft, and only for an authenticated tenant; the owner decides	Embedding-based classifier and red-team corpus (PyRIT/garak) in CI
R5	**Blockchain registry is simulated locally.** `tx_hash/block_number` in the registry are generated locally, not real chain data; double-pledge protection covers only this instance.	Medium	Open	Same hashing and first-pledge rule as the contract	Deploy `InvoiceRegistry.sol` on FISCO BCOS (C16)

ID	Risk	Severity	Status	Current mitigation	Planned fix
R6	**Encryption at rest is optional** outside production/staging mode.	Medium	Mitigated	Startup refuses `COPILOT_ENV=production`/`staging` without `COPILOT_DATA_KEY`; owner-only file modes	Key management via KMS/HSM, key rotation
R7	**Rate limiter is in memory, per process** and resets on restart.	Medium	Open	Per-IP token bucket; trusted-proxy hop handling	Shared limiter (Redis) or gateway-level limits
R8	**SSRF guard resolves the host before the request**, so DNS rebinding between check and connect is not fully excluded.	Medium	Open	Private, loopback, link-local and metadata ranges blocked; endpoint probes need a tenant token	Pin the resolved IP for the connection, or route through an egress proxy
R9	**Frontend dependency advisories** (`npm audit --omit=dev`: 13; 1 critical in `next` 14.x Image Optimizer, 6 high mostly in the tailwind/postcss build chain).	Medium	Mitigated	The Image Optimizer is switched off (`images: { unoptimized: true }` in `next.config.js`) and the app does not use `next/image`, so the critical advisory has no reachable code path. The high findings are build-time tooling.	Upgrade to a patched `next` major and tailwind 4 after the competition freeze
R10	**User-supplied cloud API keys** are kept in browser `localStorage` and sent per request.	Low	Mitigated	Keys never written server-side; pasted keys in chat are detected and refused (log #20)	Server-side encrypted vault per tenant
R11	**Decision-table inputs convert Decimal ratios to float** (e.g. APR vs. 36% ceiling). An exact-boundary value could classify differently by rounding. Money itself stays Decimal.	Low	Open	Ratios only; money results and JSON outputs stay Decimal strings	Pass decimal strings to the rule engine
R12	**CORS allows any local port when `ALLOWED_ORIGINS` is unset** (development convenience).	Low	Mitigated	`.env.example` sets `ALLOWED_ORIGINS`; compose deployments set it	Fail closed when unset outside development
R13	**Owner-side social engineering.** A prepared request could be sent by an owner who was misled.	Low	Mitigated	Request shows true APR and predatory flag; nothing is sent automatically	Second-person confirmation for large amounts

ID	Risk	Severity	Status	Current mitigation	Planned fix
R14	**Local model weights are downloaded from Hugging Face.** A compromised upstream model would affect narration quality.	Low	Mitigated	Model never computes figures (grounding check C13); download is an explicit, authenticated action	Pin model revision hash and verify checksums

No risk in this register allows funds to be moved by the system, because Tier 3 has no execution route.

---

6. Evidence Index

Evidence	File
Security test suite run (54 passed, 1 skipped)	`evidence/pytest_security_suite.log`
Full test suite run (969 passed, 1 skipped)	`../06-execution-evidence/logs/pytest_full_run.log`
Sandbox attack and operation replay (34/34)	`../06-execution-evidence/logs/sandbox_operation_log.md` / `.jsonl`
Ledger and registry state after the replay	`../06-execution-evidence/logs/sandbox_final_state.json`
Frontend production dependency audit	`evidence/npm_audit_production.txt`
Python dependency audit	`evidence/pip_audit_requirements.txt`

Reproduce:

```
python -m pytest tests/security -q
python submission/06-execution-evidence/run_sandbox_evidence.py
npm audit --omit=dev
```